

Tài liệu: Active Reconnaissance in Internal Networks: Covert Scanning Methods in Zero Trust Security Settings

Giới thiệu và Bối cảnh của Active Reconnaissance trong Môi trường Zero Trust Security

Giới thiệu về Active Reconnaissance

Active reconnaissance trong các mạng nội bộ là một khía cạnh quan trọng của **an ninh mạng**, đặc biệt trong bối cảnh của các thiết lập **Zero Trust security**. Kỹ thuật này liên quan đến việc chủ động kiểm tra và quét mạng để thu thập thông tin về các nguồn tài nguyên, topo và các lỗ hổng tiềm ẩn. Mục tiêu chính là xác định các vector tấn công tiềm năng và tăng cường khả năng phòng thủ của mạng một cách chủ động.

Bối cảnh của Active Reconnaissance trong Zero Trust Security

Zero Trust security là một mô hình an ninh mạng hiện đại hoạt động dựa trên nguyên tắc “không bao giờ tin tưởng, luôn luôn xác minh”. Mô hình này giả định rằng không có người dùng hay thiết bị nào trong mạng tự động được tin tưởng và yêu cầu xác thực và ủy quyền liên tục cho tất cả các yêu cầu truy cập. Trong bối cảnh này, active reconnaissance trở nên thiết yếu để duy trì tính toàn vẹn và an ninh của mạng.

Tầm quan trọng của Active Reconnaissance

Active reconnaissance giúp đạt được nhiều lợi ích: 1. **Xác định lỗ hổng**: Bằng cách quét mạng một cách chủ động, bạn có thể xác định những lỗ hổng tiềm năng mà kẻ tấn công có thể khai thác. 2. **Tăng cường phát hiện mối đe dọa**: Nó cho phép triển khai các cơ chế phát hiện mối đe dọa hiệu quả hơn, chẳng hạn như hệ thống phát hiện dựa trên bất thường. 3. **Cải thiện phản ứng sự cố**: Việc phát hiện sớm các mối đe dọa tiềm năng cho phép phản ứng sự cố nhanh chóng hơn, giảm thiểu tác động của một cuộc tấn công thành công. 4. **Quản lý tuân thủ và rủi ro**: Quét mạng thường xuyên giúp duy trì tuân thủ các tiêu chuẩn an ninh và giảm thiểu tư thế rủi ro chung của tổ chức.

Thách thức trong Active Reconnaissance

Mặc dù có vai trò quan trọng, active reconnaissance cũng đối mặt với một số thách thức: 1. **Độ phức tạp của mạng**: Các mạng hiện đại rất phức tạp, làm cho việc lập bản đồ tất cả các con đường và nguồn tài nguyên tiềm năng trở nên khó khăn. 2. **Kỹ thuật né tránh**: Kẻ tấn công thường sử dụng các kỹ thuật né tránh để tránh bị phát hiện, khiến việc nhận diện hoạt động độc hại trở nên thách thức. 3. **Cường độ sử dụng tài nguyên**: Quá trình quét chủ

động có thể tiêu tốn nhiều tài nguyên, có khả năng ảnh hưởng đến hiệu suất mạng.

Thực tiễn tốt nhất cho việc triển khai Active Reconnaissance

Để triển khai active reconnaissance hiệu quả trong môi trường **Zero Trust**, hãy xem xét những thực tiễn tốt nhất sau: - **Phân đoạn mạng**: Triển khai phân đoạn mạng để cách ly các tài nguyên quan trọng và hạn chế phạm vi thiệt hại của bất kỳ cuộc xâm phạm tiềm năng nào. - **Giám sát liên tục**: Sử dụng các công cụ giám sát liên tục để theo dõi hoạt động trên mạng theo thời gian thực, cho phép phát hiện sớm các bất thường. - **Phân tích dựa trên AI**: Tận dụng phân tích dựa trên AI để nâng cao khả năng phát hiện mối đe dọa và cải thiện độ chính xác của việc phát hiện bất thường.

Công cụ và công nghệ

Nhiều công cụ và công nghệ có sẵn để triển khai active reconnaissance: - **Nmap**: Một công cụ quét mạng phổ biến có thể được sử dụng để liệt kê các tài nguyên mạng và xác định các lỗ hổng tiềm năng. Ví dụ lệnh CLI: `nmap -sS -O 192.168.1.0/24` (quét TCP SYN với phát hiện Hệ điều hành). - **ZAP (Zed Attack Proxy)**: Một công cụ quét an ninh ứng dụng web mã nguồn mở có thể được sử dụng để xác định các lỗ hổng trong các ứng dụng web. Ví dụ lệnh CLI: `zap -scan 192.168.1.100` (quét một địa chỉ IP cụ thể). - **OSSEC**: Một hệ thống phát hiện xâm nhập trên máy chủ (HIDS) mã nguồn mở có thể được sử dụng để theo dõi các cuộc gọi hệ thống và phát hiện các cuộc xâm nhập tiềm tàng. Ví dụ đoạn mã cấu hình: `[syscheck]` (tệp cấu hình OSSEC).

Tài liệu tham khảo

Để tìm hiểu thêm, tham khảo các nguồn sau: - **MITRE ATT&CK Framework**: Cung cấp một khung toàn diện để hiểu và mô tả các chiến thuật, kỹ thuật và quy trình (TTP) của kẻ thù mạng. [1] - **OWASP**: Cung cấp nhiều thông tin về an ninh ứng dụng web, bao gồm các công cụ và thực tiễn tốt nhất cho quét lỗ hổng. [2] - **Tài liệu chính thức của nhà cung cấp**: Các công cụ như Nmap và ZAP có tài liệu phong phú trên trang web chính thức của họ, chi tiết về cách sử dụng và tùy chọn cấu hình.

Bằng cách hiểu bối cảnh và tầm quan trọng của active reconnaissance trong các thiết lập Zero Trust, các tổ chức có thể chuẩn bị tốt hơn trước các mối đe dọa tiềm ẩn và duy trì tư thế an ninh vững chắc.

Tài liệu tham khảo: [1] MITRE ATT&CK Framework. (n.d.). Retrieved from <https://attack.mitre.org/>

[2] OWASP. (n.d.). Retrieved from <https://owasp.org/>

[3] Nmap. (n.d.). Retrieved from <https://nmap.org/>

[4] ZAP (Zed Attack Proxy). (n.d.). Retrieved from <https://www.zaproxy.org/>

[5] OSSEC. (n.d.). Retrieved from <https://ossec.net/>

2. Tổng quan về Mô hình Bảo mật Zero Trust

Zero Trust là một phương pháp bảo mật hiện đại hoạt động theo nguyên tắc “không bao giờ tin tưởng, luôn luôn xác minh”. Khung lý thuyết này thay đổi căn bản cách các tổ chức kiến trúc hạ tầng và quản lý quyền truy cập vào tài nguyên. Dưới đây là một cái nhìn chi tiết về mô hình Zero Trust, tập trung vào các nguyên tắc cốt lõi và các phát triển gần đây:

Các Nguyên Tắc Chính của Zero Trust

- **Không bao giờ tin tưởng, luôn luôn xác minh:** Nguyên tắc này loại bỏ giả định rằng một người dùng hoặc thiết bị bên trong mạng là đã được xác thực và ủy quyền. Thay vào đó, mỗi yêu cầu truy cập phải được xác thực và ủy quyền riêng lẻ[1][3].
- **Microsegmentation:** Bao gồm việc cách ly người dùng và tài sản trong mạng để ngăn chặn việc di chuyển ngang và chứa đựng các cuộc tấn công. Hệ thống microsegmentation có thể khó triển khai triệt để, do đó thường tập trung vào việc cách ly quyền truy cập vào các tài nguyên quan trọng (crown jewels) là thiết thực hơn[1][3].
- **Truy cập với Quyền hạn Tối thiểu:** Người dùng và thiết bị chỉ nên có các quyền hạn tối thiểu cần thiết để thực hiện công việc của họ. Điều này giúp giảm bề mặt tấn công bằng cách giới hạn thiệt hại mà kẻ tấn công có thể gây ra[1][3].
- **Xác thực Liên tục:** Người dùng và thiết bị nên được xác thực và xác thực lại liên tục, đặc biệt khi truy cập vào các tài nguyên nhạy cảm. Điều này có thể đạt được thông qua xác thực đa yếu tố (MFA) và các phương pháp xác thực nâng cao khác[1][3].
- **Phân đoạn Mạng:** Phân đoạn liên quan đến việc chia mạng thành các đoạn nhỏ hơn để hạn chế sự lan rộng của các cuộc tấn công. Điều này có thể được thực hiện bằng cách sử dụng các kỹ thuật như mạng cục bộ ảo (VLAN) và mạng định nghĩa bằng phần mềm (SDN)[1][3].

Các Phát Triển Gần Đây và Thực Hành Tốt Nhất

- **Zero Trust Network Access (ZTNA):** ZTNA mở rộng các nguyên tắc của zero trust cho người lao động từ xa bằng cách đảm bảo rằng tất cả các truy cập vào tài nguyên, dù là ở văn phòng hay từ xa, đều được xác thực và ủy quyền. Điều này có thể loại bỏ nhu cầu về kiểm soát truy cập mạng (NAC) và tăng cường tư thế bảo mật[1].
- **Tích hợp Bảo mật DNS:** Các chiến lược Zero Trust thường bỏ qua bảo mật DNS, đây là một thành phần quan trọng trong giao tiếp mạng. Tích hợp bảo mật DNS bao gồm các kỹ thuật như DNS phân tách chân trời, tạo ra các chế độ xem DNS riêng biệt cho các truy vấn nội bộ và bên ngoài, giúp giảm thiểu sự tiếp xúc với các cuộc tấn công do thám[3].

- **Quản lý Lỗ hổng:** Trong bối cảnh zero trust, quản lý lỗ hổng là rất quan trọng. Các tổ chức nên ưu tiên các lỗ hổng đang bị khai thác tích cực thay vì những lỗ hổng nghiêm trọng nhưng hiếm khi bị khai thác. AI có thể cải thiện quản lý lỗ hổng bằng cách cung cấp sự ưu tiên thông minh hơn và quản lý lỗ hổng thống nhất[1].

Cấu Hình và Triển Khai

Mặc dù phần này tập trung vào cái nhìn tổng quan hơn là các bước triển khai, cần lưu ý rằng zero trust không phải là một sản phẩm hoặc giải pháp duy nhất mà là một khung bậc thầy. Dưới đây là một số cấu hình và xem xét chính:

- **Quản lý Danh tính và Quyền truy cập (IAM):** IAM nên được kiểm soát chặt chẽ theo nguyên tắc truy cập với quyền hạn tối thiểu. Việc triển khai MFA và kiểm soát quyền truy cập dựa trên vai trò (RBAC) đảm bảo rằng chỉ những nhân viên có quyền hạn mới có thể thay đổi cấu hình quan trọng[3].
- **Phân đoạn Mạng:** Hạn chế giải quyết DNS cho các ứng dụng quan trọng, sử dụng micro-segmentation để giới hạn quyền truy cập DNS chỉ cho các điểm cuối đáng tin cậy, và áp dụng quy tắc tường lửa để chặn các yêu cầu DNS ra ngoài từ các thiết bị không được ủy quyền[3].
- **Giám sát Liên tục:** Tích hợp bảo mật DNS với các nền tảng SIEM cho phép giám sát liên tục và phát hiện anomaly nâng cao. Việc tận dụng phân tích dựa trên AI giúp xác định các hành vi DNS đáng ngờ có thể chỉ ra các mối đe dọa mạng[3].

Tham Khảo

- [1] The Hacker News: “What it Means to ‘Fight AI with AI’ using a Zero Trust Platform”
- [3] Cygna Labs: “Why DNS Security is the Missing Link in Zero Trust Strategies”
- [OWASP]: “Zero Trust Architecture” (for detailed guidelines and best practices)
- [MITRE]: “Zero Trust Architecture” (for detailed guidelines and best practices)

Phần tổng quan này cung cấp một cái nhìn toàn diện về mô hình bảo mật zero trust, tập trung vào các nguyên tắc cốt lõi và các phát triển gần đây. Điều này tạo điều kiện cho các phần tiếp theo đi sâu vào các kỹ thuật do thám chủ động và các tác động của chúng trong các môi trường zero trust.

Technical Background on Covert Scanning Techniques

Giới thiệu

Các kỹ thuật **covert scanning** đóng vai trò quan trọng trong bối cảnh **active reconnaissance**, đặc biệt là trong các môi trường bảo mật **zero trust**. Những phương pháp này nhằm thu thập thông tin về các mạng nội bộ mà không bị phát hiện bởi các hệ thống bảo mật. Phần này sẽ đi sâu vào nền tảng kỹ thuật của các kỹ thuật covert scanning, tập trung vào những phát triển gần đây và các best practices.

Các loại kỹ thuật covert scanning

1. DNS Interrogation

- **Mô tả:** DNS interrogation liên quan đến việc truy vấn các máy chủ DNS để thu thập thông tin về mạng mục tiêu. Điều này có thể bao gồm việc xác định các subdomain, giải quyết địa chỉ IP và phát hiện các cuộc tấn công **DNS tunneling**.
- **Công cụ và kỹ thuật:**
 - **nslookup:** Công cụ dòng lệnh được sử dụng để truy vấn các máy chủ DNS. Ví dụ sử dụng:
`nslookup -type=mx example.com`
Lệnh này giải quyết các bản ghi **MX** cho miền **example.com**.
 - **DNSRecon:** Một script Python thực hiện các tác vụ thu thập thông tin liên quan đến DNS, bao gồm việc xác định subdomain và phát hiện các cuộc tấn công DNS tunneling.

2. Port Scanning

- **Mô tả:** Port scanning liên quan đến việc gửi các gói tin đến một máy chủ mục tiêu để xác định các cổng đang mở. Điều này có thể giúp xác định các điểm vào tiềm năng cho các kẻ tấn công.
- **Công cụ và kỹ thuật:**
 - **Nmap:** Công cụ quét cổng phổ biến hỗ trợ nhiều kỹ thuật quét khác nhau, bao gồm **SYN**, **NULL**, và **FIN scans**. Ví dụ sử dụng:
`nmap -sS -p 1-1024 <target_ip>`
Lệnh này thực hiện một **SYN scan** trên các cổng 1-1024 của địa chỉ IP mục tiêu.
 - **Masscan:** Một công cụ quét cổng nhanh và nhẹ có thể quét các khoảng địa chỉ IP lớn một cách nhanh chóng. Ví dụ sử dụng:
`masscan -sS -p 1-1024 <target_ip>`
Lệnh này thực hiện một **SYN scan** trên các cổng 1-1024 của địa chỉ IP mục tiêu bằng cách sử dụng Masscan.

3. Network Scanning

- **Mô tả:** Network scanning liên quan đến việc thu thập thông tin về mạng mục tiêu bằng cách gửi các probes đến nhiều máy chủ và dịch vụ khác nhau.
- **Công cụ và kỹ thuật:**

- **Nmap**: Có thể thực hiện các tác vụ quét mạng như xác định các máy chủ sống, cổng mở và các dịch vụ đang chạy trên các cổng đó.
- **ZMap**: Một công cụ quét mạng nhanh có thể nhanh chóng xác định các máy chủ sống và cổng mở. Ví dụ sử dụng:

```
zmap -sS -p 1-1024 <target_ip>
```

Lệnh này thực hiện một **SYN scan** trên các cổng 1-1024 của địa chỉ IP mục tiêu bằng cách sử dụng ZMap.

4. Social Engineering

- **Mô tả**: Social engineering liên quan đến việc thao túng các cá nhân để tiết lộ thông tin nhạy cảm hoặc thực hiện các hành động nhất định có thể gây tổn hại đến bảo mật.
- **Công cụ và kỹ thuật**:
 - **Phishing**: Gửi email hoặc tin nhắn giả mạo dường như đến từ một nguồn đáng tin cậy để đánh lừa người dùng tiết lộ thông tin nhạy cảm.
 - **Spear Phishing**: Các cuộc tấn công phishing có mục tiêu nhắm vào các cá nhân hoặc nhóm cụ thể trong tổ chức.
 - **Vishing: Voice phishing**, nơi kẻ tấn công sử dụng cuộc gọi điện thoại để đánh lừa người dùng tiết lộ thông tin nhạy cảm.

5. Active Footprinting

- **Mô tả**: Active footprinting liên quan đến việc tương tác trực tiếp với hệ thống mục tiêu để thu thập thông tin. Điều này có thể bao gồm **DNS interrogation**, **port scanning**, và **social engineering**.
- **Công cụ và kỹ thuật**:
 - **DNS Interrogation**: Sử dụng các công cụ như nslookup hoặc DNSRecon để truy vấn các máy chủ DNS và thu thập thông tin về mạng mục tiêu.
 - **Port Scanning**: Sử dụng các công cụ như Nmap hoặc Masscan để xác định các cổng mở và dịch vụ đang chạy trên các cổng đó.
 - **Social Engineering**: Sử dụng các kỹ thuật như phishing hoặc vishing để thao túng cá nhân tiết lộ thông tin nhạy cảm.

Cơ chế phát hiện và giới hạn

1. Hệ thống phát hiện xâm nhập (IDS)

- IDS có thể phát hiện các hoạt động mạng đáng ngờ, bao gồm **port scanning** và **DNS interrogation**. Tuy nhiên, chúng có thể bị vượt qua bằng các kỹ thuật quét tinh vi hoặc kỹ thuật lẩn tránh.

2. Tường lửa

- Tường lửa có thể chặn lưu lượng vào và ra dựa trên các quy tắc được xác định trước. Tuy nhiên, chúng có thể được cấu hình để cho phép các loại lưu lượng nhất định có thể được sử dụng cho reconnaissance.

3. Hệ thống quản lý thông tin và sự kiện bảo mật (SIEM)

- Hệ thống SIEM thu thập và phân tích dữ liệu log từ nhiều thiết bị bảo mật để xác định các mối đe dọa tiềm năng. Tuy nhiên, chúng

yêu cầu cấu hình và giám sát phù hợp để phát hiện các hoạt động covert scanning một cách hiệu quả.

4. Phân đoạn mạng

- Phân đoạn mạng liên quan đến việc chia nhỏ mạng thành các đoạn nhỏ hơn để hạn chế sự lây lan của các cuộc tấn công. Điều này có thể giúp ngăn chặn các cuộc quét reconnaissance lây lan ra toàn bộ mạng.

Các best practices cho việc phát hiện covert scanning

1. củng cố cấu hình DNS

- Vô hiệu hóa zone transfers và hạn chế quyền truy cập vào các máy chủ DNS để ngăn ngừa việc truy vấn DNS trái phép.

2. Triển khai tường lửa và IDS/IPS

- Cấu hình tường lửa để chặn các mẫu lưu lượng đáng ngờ và triển khai các hệ thống IDS/IPS để phát hiện và ngăn chặn các hoạt động reconnaissance.

3. Giám sát hoạt động không bình thường

- Triển khai các giải pháp giám sát liên tục để phát hiện hành vi quét DNS hoặc mạng không bình thường.

4. Đào tạo nhân viên

- Giáo dục nhân viên về cách nhận diện các email phishing và các chiến thuật xã hội khác để ngăn họ tiết lộ thông tin nhạy cảm.

5. Giới hạn các dịch vụ không cần thiết

- Đóng các cổng không sử dụng và hạn chế các dịch vụ không cần thiết để giảm bề mặt tấn công.

Bằng cách hiểu rõ các kỹ thuật covert scanning và triển khai các cơ chế phát hiện hiệu quả, các tổ chức có thể củng cố tư thế bảo mật **zero trust** của họ và giảm thiểu các rủi ro liên quan đến **active reconnaissance**.

Tài liệu tham khảo: - [3] Cygnalabs. (2025, March 25). Why DNS Security is the Missing Link in Zero Trust Strategies. - [5] Webasha. (2025, April 4). What is Active Footprinting in Cybersecurity and Why Does It Matter? - [1] MITRE. (n.d.). Common Vulnerabilities and Exposures (CVE). - [2] OWASP. (n.d.). Web Application Security Testing.

So sánh giữa Active Reconnaissance và Passive Reconnaissance

Giới thiệu

Active reconnaissance và passive reconnaissance là hai phương pháp khác nhau được sử dụng trong đánh giá an ninh mạng nhằm thu thập thông tin về hệ thống hoặc mạng mục tiêu. Hiểu rõ sự khác biệt giữa các phương pháp này rất quan trọng cho các chiến lược an ninh hiệu quả, đặc biệt trong các môi trường zero trust.

Các điểm khác biệt chính

- **Tương tác trực tiếp vs. Quan sát gián tiếp**
 - **Active Reconnaissance:** Bao gồm việc tương tác trực tiếp với hệ thống hoặc mạng mục tiêu để thu thập thông tin. Điều này có thể bao gồm các kỹ thuật như thăm vắn DNS, quét cổng, và kỹ thuật xã hội (social engineering)[5].
 - **Passive Reconnaissance:** Bao gồm việc thu thập thông tin mà không tương tác trực tiếp với mục tiêu. Điều này bao gồm việc thu thập dữ liệu từ những nguồn công khai, chẳng hạn như bản ghi DNS, địa chỉ IP và thông tin tình báo nguồn mở (open-source intelligence)[5].
- **Rủi ro phát hiện**
 - **Active Reconnaissance:** Để lại dấu vết có thể phát hiện và có thể kích hoạt cảnh báo trong các hệ thống phát hiện xâm nhập (IDS) hoặc quy tắc tường lửa. Phương pháp này được coi là quyết liệt hơn và có rủi ro cao hơn[5].
 - **Passive Reconnaissance:** Ít có khả năng bị phát hiện hơn do không liên quan đến việc tương tác trực tiếp với hệ thống mục tiêu. Tuy nhiên, nó vẫn có thể để lại một số dấu vết kỹ thuật số mà có thể được phát hiện bằng các công cụ giám sát tiên tiến[5].
- **Trường hợp sử dụng**
 - **Active Reconnaissance:** Thường được sử dụng trong kiểm tra thâm nhập, hacking đạo đức và các hoạt động red teaming để mô phỏng các cuộc tấn công thực tế. Nó giúp xác định các hệ thống hoạt động, tiết lộ các điểm truy cập và thông báo các bước tiếp theo cho việc quét lỗ hổng hoặc vá lỗi[5].
 - **Passive Reconnaissance:** Thường được sử dụng cho quá trình thu thập thông tin ban đầu nhằm thu thập thông tin tổng quát về một mục tiêu trước khi quyết định áp dụng phương pháp tích cực hơn. Phương pháp này giúp xác định các lỗ hổng tiềm ẩn mà không rủi ro bị phát hiện[5].

Các yếu tố kỹ thuật

- **Công cụ và kỹ thuật**
 - **Công cụ Active Reconnaissance:**
 - * nmap cho việc quét cổng
 - * nslookup cho truy vấn DNS
 - * enum4linux cho việc liệt kê tài khoản người dùng
 - * Các công cụ xã hội như email lừa đảo hoặc cuộc gọi điện thoại[5]
 - **Công cụ Passive Reconnaissance:**
 - * Công cụ thu thập thông tin nguồn mở
 - * Công cụ lấy thông tin từ bản ghi DNS
 - * Dịch vụ tra cứu địa chỉ IP
 - * Công cụ giám sát mạng xã hội[5]

- **Cơ chế phát hiện**
 - **Phát hiện Active Reconnaissance:**
 - * Hệ thống IDS/IPS có thể phát hiện và ghi lại hoạt động nghi ngờ.
 - * Tường lửa có thể chặn hoặc giới hạn truy cập dựa trên các quy tắc đã định trước.
 - * Công cụ giám sát mạng có thể xác định các mẫu lưu lượng bất thường[5].
 - **Phát hiện Passive Reconnaissance:**
 - * Các công cụ giám sát tiên tiến có thể phát hiện các bất thường trong lưu lượng mạng.
 - * Các thuật toán **Machine Learning** có thể xác định các mẫu thể hiện sự tiến hành passive reconnaissance[5].

Giới hạn và rủi ro

- **Rủi ro của Active Reconnaissance:**
 - Bị phát hiện bởi các hệ thống an ninh.
 - Các vấn đề pháp lý nếu tiến hành mà không có sự cho phép.
 - N disrupted hệ thống do quá trình quét quyết liệt[5].
- **Rủi ro của Passive Reconnaissance:**
 - Việc thu thập thông tin có giới hạn so với các phương pháp chủ động.
 - Có khả năng bỏ lỡ các lỗ hổng quan trọng nếu không được kết hợp với các kỹ thuật chủ động[5].

Kết luận

Hiểu biết về sự khác biệt giữa active và passive reconnaissance là rất quan trọng cho các chiến lược an ninh mạng hiệu quả, đặc biệt trong các môi trường zero trust. Trong khi active reconnaissance cung cấp thông tin chi tiết hơn, nó đi kèm với rủi ro cao hơn về phát hiện và gián đoạn hệ thống. Ngược lại, passive reconnaissance ít rủi ro hơn nhưng có thể không tiết lộ tất cả các lỗ hổng tiềm ẩn. Một cách tiếp cận cân bằng kết hợp cả hai phương pháp có thể cung cấp các đánh giá an ninh toàn diện.

Tài liệu tham khảo

- [1] MITRE ATT&CK Framework - Active Reconnaissance Techniques
- [2] OWASP - Reconnaissance
- [3] GitHub - nmap/nmap (port scanning tool)
- [4] GitHub - dnsrecon/dnsrecon (DNS interrogation tool)
- [5] Cygnalabs Blog - Active Footprinting in Cybersecurity and Why It Matters

Kiến trúc Hệ thống cho Các Công cụ Reconnaissance Chủ động

Tổng quan

Các công cụ **reconnaissance chủ động** trong môi trường **Zero Trust** yêu cầu một kiến trúc hệ thống vững chắc để đảm bảo hoạt động hiệu quả mà không làm tổn hại đến tính toàn vẹn của mạng. Dưới đây là phân tích chi tiết về kiến trúc hệ thống cho các công cụ reconnaissance chủ động, tập trung vào các phát triển gần đây và thông số kỹ thuật kỹ thuật.

Thành phần chính

- **Phân đoạn Mạng:** Các mạng **Zero Trust** được thiết kế để phân đoạn tài nguyên thành các micro-segment nhằm hạn chế chuyển động ngang. Việc phân đoạn này rất quan trọng cho reconnaissance chủ động vì nó giúp cô lập hoạt động quét vào các phân đoạn cụ thể, giảm thiểu rủi ro bị phát hiện và tối thiểu hóa diện tích tấn công [1][3].
- **Quản lý Danh tính và Quyền truy cập (IAM):** Các hệ thống IAM đảm bảo rằng chỉ những cá nhân được ủy quyền mới có thể thực hiện các nhiệm vụ reconnaissance chủ động. Việc triển khai xác thực đa yếu tố (MFA) và kiểm soát quyền truy cập dựa trên vai trò (RBAC) là rất cần thiết để ngăn chặn truy cập trái phép [3].
- **Theo dõi và Ghi nhật ký:** Việc theo dõi liên tục và ghi nhật ký là các thành phần quan trọng của kiến trúc hệ thống. Điều này bao gồm việc tích hợp hệ thống quản lý thông tin và sự kiện bảo mật (**SIEM**) để theo dõi mọi hoạt động trên mạng, bao gồm cả các lần quét reconnaissance. Điều này giúp phát hiện bất thường và phản ứng với các mối đe dọa tiềm năng trong thời gian thực [3][5].
- **Tường lửa và Hệ thống Phát hiện/Ngăn chặn Xâm nhập (IDS/IPS):** Tường lửa và IDS/IPS đóng một vai trò quan trọng trong việc phát hiện và chặn lưu lượng độc hại. Cấu hình tường lửa để hạn chế truy cập vào các cổng cụ thể và triển khai quy tắc IDS/IPS để xác định hoạt động khả nghi có thể nâng cao đáng kể tư thế bảo mật của mạng [5].

Thông số kỹ thuật

- **Lệnh Giao diện Dòng Lệnh (CLI):**
 - **Nmap:** Là công cụ phổ biến cho quét mạng, Nmap có thể được sử dụng để thực hiện reconnaissance chủ động. Dưới đây là ví dụ sử dụng Nmap để quét một mạng:
`nmap -sS -T4 -p 22,80,443 <target_ip>`
Lệnh này thực hiện quét TCP SYN trên các cổng 22, 80 và 443 của địa chỉ IP mục tiêu [5].

- **Xác minh DNS:** Các công cụ như `nslookup` có thể được sử dụng để xác minh DNS:
`nslookup -type=mx <domain_name>`
 Lệnh này thực hiện việc tìm kiếm bản ghi MX DNS cho tên miền đã chỉ định [5].
- **Tệp cấu hình:**
 - **Tệp cấu hình Nmap:** Nmap cho phép cấu hình qua một tệp. Dưới đây là ví dụ về một tệp cấu hình Nmap cơ bản:
`# Tệp cấu hình Nmap ví dụ`
`max_parallelism=100`
`max_rtt_time=1000ms`
 Tệp cấu hình này thiết lập số lượng quét đồng thời tối đa và thời gian quay vòng tối đa cho mỗi lần quét [5].
 - **Mã Python cho Reconnaissance Chủ động:** Một đoạn mã Python đơn giản sử dụng thư viện `scapy` có thể được sử dụng để thực hiện reconnaissance chủ động:

```
from scapy.all import IP, TCP, sr1

def scan_port(ip, port):
    packet = IP(dst=ip)/TCP(dport=port, flags="S")
    response = sr1(packet, timeout=1, verbose=0)
    if response:
        return True
    else:
        return False

# Ví dụ sử dụng
ip_address = "192.168.1.100"
port_number = 80

if scan_port(ip_address, port_number):
    print(f"Port {port_number} is open on {ip_address}")
else:
    print(f"Port {port_number} is closed on {ip_address}")
```

 Đoạn mã này gửi một gói TCP SYN đến địa chỉ IP và cổng được chỉ định, và kiểm tra phản hồi để xác định xem cổng có mở hay không [4].

Công cụ và Công nghệ

- **Nmap:** Là một công cụ quét mạng mạnh mẽ hỗ trợ nhiều kỹ thuật quét khác nhau, bao gồm quét SYN, NULL và FIN [5].
- **Scapy:** Thư viện thao tác gói dựa trên Python, có thể được sử dụng để tạo và gửi các gói mạng tùy chỉnh cho reconnaissance [4].
- **DNSRecon:** Công cụ được thiết kế đặc biệt cho reconnaissance DNS, có

thể thực hiện các tra cứu DNS và xác định các lỗ hổng tiềm ẩn [5].

Kết luận

Kiến trúc hệ thống cho các công cụ reconnaissance chủ động trong môi trường **Zero Trust** phải vững chắc và an toàn. Bằng cách triển khai phân đoạn mạng, hệ thống IAM, theo dõi liên tục và cấu hình tường lửa cùng IDS/IPS, các tổ chức có thể giảm thiểu hiệu quả các rủi ro liên quan đến reconnaissance chủ động trong khi duy trì mức độ bảo mật cao. Việc sử dụng các công cụ như Nmap, Scapy và DNSRecon có thể nâng cao đáng kể hiệu quả của các hoạt động reconnaissance chủ động.

Enumeration of Network Resources in Zero Trust Environments

Tổng Quan

Trong một mô hình bảo mật **Zero Trust**, việc liệt kê các tài nguyên mạng là rất quan trọng để duy trì tầm nhìn và kiểm soát đối với mạng. Quá trình này bao gồm việc xác định và lập danh mục tất cả các thiết bị, dịch vụ và ứng dụng trong mạng nhằm đảm bảo chỉ các thực thể được ủy quyền mới có quyền truy cập vào các tài nguyên nhạy cảm. Dưới đây là các điểm chính cần xem xét:

Kỹ Thuật Để Liệt Kê Các Tài Nguyên Mạng

1. DNS Enumeration

- **DNS Querying:** Sử dụng các công cụ như `nslookup` hoặc `dig` để truy vấn các bản ghi DNS và xác định các tên miền phụ, địa chỉ IP, và vị trí dịch vụ.
- **DNS Scanning:** Các công cụ như `dnsrecon` có thể thực hiện các quét DNS toàn diện để thu thập thông tin chi tiết về mạng mục tiêu.
- **Split-Horizon DNS:** Việc triển khai split-horizon DNS có thể giúp tách biệt các cái nhìn DNS nội bộ và bên ngoài, giảm thiểu khả năng bị tấn công do gián điệp.

2. Network Scanning

- **Port Scanning:** Sử dụng các công cụ như `nmap` để quét các cổng mở và xác định các dịch vụ đang chạy. Điều này giúp hiểu rõ bề mặt tấn công của mạng.
- **Service Enumeration:** Các công cụ như `enum4linux` có thể liệt kê các dịch vụ đang chạy trên các máy chủ Windows, cung cấp thông tin chi tiết về tài khoản người dùng và cấu hình dịch vụ.

3. Service Discovery

- **Service Mesh:** Triển khai các công nghệ service mesh như Istio hoặc Linkerd để giúp phát hiện và quản lý các microservices trong mạng.
- **API Discovery:** Sử dụng các công cụ như `swagger` hoặc `OpenAPI` để khám phá và tài liệu hóa các API, đảm bảo rằng chỉ các dịch vụ

được ủy quyền mới có thể truy cập dữ liệu nhạy cảm.

4. Quản Lý Danh Mục

- **CMDDB (Configuration Management Database):** Duy trì một CMDDB để theo dõi tất cả phần cứng, phần mềm, và cấu hình mạng. Điều này giúp đảm bảo rằng tất cả thiết bị và dịch vụ đều được ghi nhận và bảo mật đúng cách.
- **Quản Lý Địa Chỉ IP (IPAM):** Các công cụ như IPAM tập trung từ Cygna Labs giúp quản lý các địa chỉ IP và đảm bảo rằng chỉ các thiết bị được ủy quyền mới có thể truy cập vào mạng.

5. Giám Sát Liên Tục

- **SIEM Integration:** Tích hợp các hệ thống quản lý thông tin và sự kiện bảo mật (SIEM) để giám sát liên tục hoạt động mạng và phát hiện bất kỳ sự bất thường nào.
- **Phân Tích Nhật Ký:** Thường xuyên phân tích nhật ký từ các nguồn khác nhau để xác định các mối đe dọa bảo mật tiềm ẩn và đảm bảo rằng tất cả tài nguyên mạng đều được bảo vệ đúng cách.

Thực Hành Tốt Nhất

1. Phân Segmentation

- Triển khai phân đoạn mạng để cách ly các tài nguyên quan trọng và giới hạn quyền truy cập chỉ vào các dịch vụ cần thiết.
- Sử dụng các kỹ thuật micro-segmentation để hạn chế quyền truy cập và ngăn chặn di chuyển bên trong mạng.

2. Kiểm Soát Truy Cập

- Thực hiện các kiểm soát truy cập nghiêm ngặt sử dụng kiểm soát truy cập dựa trên vai trò (RBAC) và xác thực đa yếu tố (MFA) để đảm bảo rằng chỉ những người có thẩm quyền mới có thể truy cập vào các tài nguyên nhạy cảm.
- Thường xuyên xem xét và cập nhật các chính sách truy cập để phản ánh các thay đổi trong môi trường mạng.

3. Giám Sát và Nhật Ký

- Triển khai tường lửa và hệ thống phát hiện xâm nhập (IDS/IPS) để giám sát lưu lượng mạng và phát hiện các mối đe dọa tiềm ẩn.
- Bật chức năng ghi nhật ký cho tất cả các hoạt động mạng và thường xuyên phân tích nhật ký để xác định các vấn đề bảo mật có thể xảy ra.

4. Đào Tạo và Nhận Thức

- Đào tạo các quản trị viên mạng và đội ngũ an ninh về tầm quan trọng của việc giám sát liên tục và các kỹ thuật được sử dụng trong việc gián điệp chủ động.
- Giáo dục nhân viên về các rủi ro liên quan đến việc footprinting chủ động và tầm quan trọng của việc báo cáo hoạt động đáng ngờ.

Bằng cách tuân theo các thực hành tốt nhất này và tận dụng các kỹ thuật được nêu ra ở trên, các tổ chức có thể hiệu quả trong việc liệt kê các tài nguyên mạng

trong các môi trường **Zero Trust**, nâng cao tư thế bảo mật tổng thể và giảm thiểu rủi ro truy cập trái phép.

Covert Scanning Methodologies and Their Implementations

Giới thiệu

Các **phương pháp quét bí mật** là yếu tố thiết yếu trong hoạt động **reconnaissance chủ động**, đặc biệt trong các thiết lập bảo mật **Zero Trust**, nơi mà sự minh bạch và kiểm soát là rất quan trọng. Những phương pháp này nhằm mục đích thu thập thông tin mà không bị hệ thống bảo mật phát hiện, vì vậy chúng rất quan trọng cho cả chiến lược tấn công và phòng thủ.

Kỹ thuật Quét Bí Mật

1. DNS Interrogation

- **Kỹ thuật:** Giao thức **DNS interrogation** liên quan đến việc truy vấn máy chủ DNS để thu thập thông tin về mạng mục tiêu. Điều này có thể bao gồm việc xác định các **subdomain**, phân giải địa chỉ IP và phát hiện **DNS tunneling**.
- **Triển khai:**
 - **Lệnh CLI:**
`nslookup -type=PTR <Địa Chỉ IP>`
 - **Ví dụ:** Sử dụng `nslookup`, bạn có thể truy vấn một địa chỉ IP cụ thể để phân giải tên máy chủ của nó và thu thập thông tin bổ sung về miền.
 - **Tài liệu tham khảo:** DNS Security is the Missing Link in Zero Trust Strategies

2. Port Scanning

- **Kỹ thuật:** **Port scanning** liên quan đến việc gửi các gói tin đến hệ thống mục tiêu để xác định các cổng mở và dịch vụ đang chạy trên các cổng đó.
- **Triển khai:**
 - **Lệnh CLI:**
`nmap -sT <Địa Chỉ IP>`
 - **Ví dụ:** Sử dụng `nmap`, bạn có thể thực hiện một quét TCP SYN để xác định các cổng đang mở trên hệ thống mục tiêu.
 - **Tài liệu tham khảo:** Active Footprinting in Cybersecurity

3. Social Engineering

- **Kỹ thuật:** **Social engineering** liên quan đến việc thao túng cá nhân để họ tiết lộ thông tin nhạy cảm hoặc thực hiện những hành động làm tổn hại đến an ninh.
- **Triển khai:**
 - **Ví dụ:** Gửi một email giả mạo từ bộ phận IT yêu cầu đặt lại mật khẩu là một chiêu thức phổ biến trong social engineering.

- Tài liệu tham khảo: Active Footprinting in Cybersecurity
- 4. Network Scanning
 - **Kỹ thuật:** **Network scanning** sử dụng các công cụ để thu thập thông tin về mạng mục tiêu, bao gồm địa chỉ IP, cổng mở và dịch vụ.
 - **Triển khai:**
 - **Lệnh CLI:**

```
nmap -sS <Địa Chỉ IP>
```
 - **Ví dụ:** Sử dụng **nmap**, bạn có thể thực hiện một quét SYN để xác định các cổng và dịch vụ đang mở trên hệ thống mục tiêu.
 - Tài liệu tham khảo: Active Footprinting in Cybersecurity
- 5. Service Enumeration
 - **Kỹ thuật:** **Service enumeration** liên quan đến việc xác định các dịch vụ đang chạy trên hệ thống mục tiêu và phiên bản của chúng.
 - **Triển khai:**
 - **Lệnh CLI:**

```
enum4linux -a <Địa Chỉ IP>
```
 - **Ví dụ:** Sử dụng **enum4linux**, bạn có thể liệt kê các tài khoản người dùng và dịch vụ trên một máy chủ Windows.
 - Tài liệu tham khảo: Active Footprinting in Cybersecurity

Phương Pháp Quét Bí Mật Nâng Cao

1. DNS Tunneling
 - **Kỹ thuật:** **DNS tunneling** sử dụng các truy vấn DNS để truyền tải dữ liệu một cách bí mật.
 - **Triển khai:**
 - **Lệnh CLI:**

```
dig +short TXT <Tên Miền>
```
 - **Ví dụ:** Sử dụng **dig**, bạn có thể truy vấn một miền để lấy các bản ghi TXT, có thể được sử dụng để **tunnel** dữ liệu.
 - Tài liệu tham khảo: DNS Security is the Missing Link in Zero Trust Strategies
2. Split-Horizon DNS
 - **Kỹ thuật:** **Split-horizon DNS** cung cấp các phản hồi DNS khác nhau cho các truy vấn nội bộ và bên ngoài, giảm thiểu nguy cơ bị tấn công từ reconnaissance.
 - **Triển khai:**
 - **Tập cấu hình:**

```
# Ví dụ cấu hình cho split-horizon DNS
zone "example.com" {
    type master;
    file "example.com.zone";
    allow-update { key "update-key"; };
    view "internal" {
        match-client { 192.168.1.0/24; };
        zone "example.com" {
```

```

        type master;
        file "example.com.internal.zone";
    };
};
view "external" {
    match-client { any; };
    zone "example.com" {
        type master;
        file "example.com.external.zone";
    };
};
};

```

- **Ví dụ:** Bằng cách cấu hình **split-horizon DNS**, bạn có thể đảm bảo rằng các bản ghi DNS nội bộ vẫn được bảo mật và không bị tiết lộ cho kẻ tấn công.
- **Tài liệu tham khảo:** DNS Security is the Missing Link in Zero Trust Strategies

Kết luận

Các phương pháp quét bí mật là rất quan trọng cho hoạt động reconnaissance chủ động trong các thiết lập bảo mật **Zero Trust**. Những kỹ thuật này, bao gồm DNS interrogation, port scanning, social engineering, network scanning, và service enumeration, giúp thu thập thông tin quan trọng mà không bị phát hiện. Các phương pháp nâng cao như DNS tunneling và split-horizon DNS càng cải thiện khả năng thực hiện các quét bí mật trong khi vẫn duy trì an ninh. Việc hiểu rõ những kỹ thuật này là điều cần thiết cho cả các chiến lược tấn công và phòng thủ trong an ninh mạng.

Tài liệu tham khảo

- DNS Security is the Missing Link in Zero Trust Strategies
- Active Footprinting in Cybersecurity
- Nmap Documentation
- Nslookup Documentation

Mô Hình Đe Dọa: Nhận Diện Các Kênh Tấn Công Trong Mạng Zero Trust

Giới thiệu về Mô Hình Đe Dọa trong Zero Trust

Mô hình đe dọa là một thành phần quan trọng trong **Zero Trust Security**, nhằm mục đích nhận diện các kênh tấn công tiềm năng và giảm thiểu rủi ro trong mạng. Trong bối cảnh **Zero Trust**, việc mô hình hóa đe dọa bao gồm

việc phân tích kiến trúc mạng và xác định các lỗ hổng có thể bị kẻ tấn công khai thác.

Nhận Diện Các Kênh Tấn Công

Để mô hình hóa các mối đe dọa hiệu quả trong môi trường **Zero Trust**, cần cân nhắc các kênh tấn công sau:

- **Lỗ Hổng Phân Đoạn Mạng:** Các phân đoạn mạng cấu hình sai có thể cung cấp các điểm vào cho kẻ tấn công. Cần đảm bảo rằng việc phân đoạn mạng được thực hiện đúng cách và thường xuyên kiểm tra để tìm kiếm lỗ hổng[1][3].
- **Rủi Ro An Ninh DNS:** DNS thường bị bỏ qua trong các chiến lược **Zero Trust**, nhưng nó là một thành phần quan trọng. Các mối đe dọa như **DNS spoofing** và **cache poisoning** có thể được giảm thiểu bằng cách thực hiện **DNSSEC** và sử dụng **split-horizon DNS**[3].
- **Vấn Đề Xác Thực và Cấp Quyền:** Các cơ chế xác thực và cấp quyền yếu có thể cho phép truy cập trái phép. Cần triển khai quản lý danh tính mạnh mẽ, xác thực đa yếu tố (**MFA**) và chính sách “quyền tối thiểu”[1][3].
- **Lỗ Hổng Điểm Cuối:** Các điểm cuối thường là mắt xích yếu nhất trong một mạng **Zero Trust**. Cần đảm bảo rằng các điểm cuối được cập nhật, vá lỗi thường xuyên và theo dõi để phát hiện hoạt động nghi ngờ[1][3].

Sử Dụng Khung MITRE ATT&CK

Khung **MITRE ATT&CK** là tài nguyên được sử dụng rộng rãi cho mô hình hóa đe dọa. Nó cung cấp danh sách toàn diện về các chiến thuật và kỹ thuật mà kẻ tấn công sử dụng, giúp nhận diện các kênh tấn công tiềm năng. Chẳng hạn, trong một môi trường **Zero Trust**, kẻ tấn công có thể sử dụng chiến thuật “Lateral Movement” để di chuyển bên trong mạng. Điều này có thể liên quan đến các kỹ thuật như “Remote Services” hoặc “Execution” để truy cập vào các tài nguyên nhạy cảm[4].

Ví Dụ Kịch Bản Đe Dọa

Dưới đây là một ví dụ về kịch bản đe dọa trong một mạng **Zero Trust**:

1. **Truy Cập Ban Đầu:** Một kẻ tấn công sử dụng kỹ thuật **social engineering** để lừa một nhân viên tiết lộ thông tin đăng nhập của họ.
2. **Thực Thi:** Kẻ tấn công sử dụng thông tin được tiết lộ để truy cập vào một dịch vụ từ xa.
3. **Di Chuyển Lateral:** Kẻ tấn công di chuyển bên trong mạng sử dụng các kỹ thuật như **Remote Services** để tiếp cận các tài nguyên nhạy cảm.
4. **Duy Trì Quyền Truy Cập:** Kẻ tấn công duy trì quyền truy cập bằng cách tạo ra các lỗ hổng hoặc sử dụng các cơ chế duy trì.

Công Cụ và Công Nghệ Cho Mô Hình Đe Dọa

Một số công cụ và công nghệ có thể hỗ trợ trong mô hình hóa đe dọa:

- **OWASP ZAP**: Một công cụ quét bảo mật ứng dụng web giúp xác định các lỗ hổng trong ứng dụng web[5].
- **Nmap**: Một công cụ quét mạng có thể được sử dụng để nhận diện các cổng mở và dịch vụ trong mạng[5].
- **DNSSEC**: Một giao thức bảo mật bảo vệ dữ liệu DNS khỏi bị giả mạo và chỉnh sửa[3].

Cấu Hình và Lệnh CLI

Dưới đây là một số lệnh CLI và ví dụ cấu hình liên quan đến mô hình hóa đe dọa:

```
# Sử dụng Nmap để quét một mạng
nmap -sV <target_ip>

# Sử dụng OWASP ZAP để quét một ứng dụng web
zap-baseline.py -target <target_url>

# Triển khai DNSSEC
# Ví dụ cấu hình cho máy chủ DNS BIND
zone "example.com" IN {
    type master;
    file "example.com.zone";
    dnssec-enable yes;
    dnssec-validation yes;
};
```

Kết Luận

Mô hình hóa đe dọa là rất cần thiết để nhận diện các kênh tấn công trong mạng **Zero Trust**. Bằng cách hiểu rõ các mối đe dọa và lỗ hổng tiềm ẩn, các tổ chức có thể triển khai các biện pháp bảo mật mạnh mẽ để giảm thiểu rủi ro. Việc thường xuyên xem xét và cập nhật các mô hình đe dọa đảm bảo rằng mạng luôn an toàn trước những mối đe dọa đang phát triển.

Tài Liệu Tham Khảo

- [1] The Hacker News. (2025, March 31). What it Means to 'Fight AI with AI' using a Zero Trust Platform. Retrieved from <https://thehackernews.com/expert-insights/2025/03/what-it-means-to-fight-ai-with-ai-using.html>
- [3] Cygna Labs. (2025, March 25). Why DNS Security is the Missing Link in Zero Trust Strategies. Retrieved from <https://cygnalabs.com/en/blog/why-dns-security-is-the-missing-link-in-zero-trust-strategies>

[4] MITRE. (n.d.). ATT&CK Framework. Retrieved from <https://attack.mitre.org/>

[5] OWASP. (n.d.). ZAP. Retrieved from https://www.owasp.org/index.php/OWASP_Zed_Attack_Proxy_Project

Tools and Technologies for Active Reconnaissance

Giới thiệu

Việc **reconnaissance chủ động** trong môi trường an ninh **zero trust** liên quan đến việc sử dụng nhiều công cụ và công nghệ khác nhau để thu thập thông tin về các mạng nội bộ. Phần này sẽ tập trung vào các công cụ và công nghệ được sử dụng cho **Active Reconnaissance**, nhấn mạnh những phát triển gần đây và chi tiết kỹ thuật.

Công cụ cho Active Reconnaissance

1. Nmap

- **Mô tả:** Nmap là một công cụ quét mạng phổ biến dùng trong việc reconnaissance chủ động. Nó có thể thực hiện nhiều loại quét khác nhau, bao gồm quét TCP SYN, UDP và ICMP.

- **Lệnh CLI:**

```
# Quét TCP SYN cơ bản  
nmap -sS <target_ip>
```

```
# Quét UDP  
nmap -sU <target_ip>
```

```
# Quét phiên bản (xác định các cổng mở và dịch vụ)  
nmap -sV <target_ip>
```

- **Tham khảo:** Nmap Official Documentation

2. DNSRecon

- **Mô tả:** DNSRecon là một công cụ được thiết kế nhằm thực hiện việc phân tích và reconnaissance DNS. Nó có thể thực hiện nhiều tác vụ liên quan đến DNS như xác định subdomain, bảng ghi DNS và các lỗi hỏng của máy chủ DNS.

- **Lệnh CLI:**

```
# Thực hiện phân tích DNS  
dnsrecon -d <target_domain> -t hosts
```

```
# Xác định các lỗi hỏng của máy chủ DNS  
dnsrecon -d <target_domain> -t dns
```

- **Tham khảo:** DNSRecon GitHub Repository

3. Enum4Linux

- **Mô tả:** Enum4Linux là một công cụ được sử dụng để thu thập thông tin từ các hệ thống Linux. Nó có thể thu thập các chi tiết như tài

khoản người dùng, thành viên nhóm và cấu hình hệ thống.

- **Lệnh CLI:**

```
# Liệt kê tài khoản người dùng
enum4linux -a <target_ip>
```

```
# Liệt kê thành viên nhóm
enum4linux -G <target_ip>
```

- **Tham khảo:** Enum4Linux GitHub Repository

4. Social Engineering Toolkit (SET)

- **Mô tả:** SET là một công cụ được sử dụng cho các cuộc tấn công kỹ thuật xã hội. Nó có thể được sử dụng để thực hiện các cuộc tấn công phishing, tạo trang web giả và thực hiện các loại tấn công kỹ thuật xã hội khác.

- **Lệnh CLI:**

```
# Tạo email phishing
setoolkit -m <email_template> -o <output_file>
```

```
# Tạo trang web giả
setoolkit -w <website_template> -o <output_file>
```

- **Tham khảo:** Social Engineering Toolkit GitHub Repository

5. Burp Suite

- **Mô tả:** Burp Suite là một bộ công cụ toàn diện cho việc kiểm tra an ninh ứng dụng web. Nó bao gồm các tính năng cho việc proxy, quét và tiêm payload vào các ứng dụng web.

- **Lệnh CLI:**

```
# Khởi động Burp Suite proxy
burpsuite -proxy <target_ip> -port <proxy_port>
```

```
# Thực hiện quét trên một ứng dụng web
burpsuite -scan <target_url>
```

- **Tham khảo:** Burp Suite Official Documentation

Công nghệ cho Active Reconnaissance

1. APIs và SDKs

- **Mô tả:** APIs và SDKs có thể được sử dụng để tương tác với các hệ thống theo cách lập trình, cho phép việc reconnaissance trở nên tinh vi và tự động hơn.

- **Ví dụ:**

```
import requests
```

```
# Ví dụ gọi API để thu thập thông tin về một hệ thống
response = requests.get('https://api.example.com/system-info')
print(response.json())
```

- **Tham khảo:** OWASP API Security Project

2. Machine Learning và AI

- **Mô tả:** Machine learning và AI có thể được sử dụng để tự động hóa các tác vụ reconnaissance và nâng cao hiệu quả của reconnaissance chủ động.

- **Ví dụ:**

```
from sklearn.model_selection import train_test_split
from sklearn.linear_model import LogisticRegression
```

Ví dụ mô hình machine learning để dự đoán các lỗ hổng

```
X_train, X_test, y_train, y_test = train_test_split(X, y, test_size=0.2, random_state=42)
model = LogisticRegression()
model.fit(X_train, y_train)
predictions = model.predict(X_test)
```

- **Tham khảo:** MITRE Machine Learning for Security

3. Containerization và Orchestration

- **Mô tả:** Các công cụ containerization và orchestration như Docker và Kubernetes có thể được sử dụng để tạo và quản lý các môi trường cho các công cụ reconnaissance.

- **Ví dụ:**

Ví dụ Dockerfile cho một công cụ reconnaissance

```
FROM python:3.9-slim
```

Cài đặt các thư viện phụ thuộc

```
RUN pip install -r requirements.txt
```

Chạy công cụ

```
CMD ["python", "recon_tool.py"]
```

- **Tham khảo:** Docker Official Documentation

4. Dịch vụ đám mây

- **Mô tả:** Các dịch vụ đám mây như AWS và Azure có thể được sử dụng để lưu trữ các công cụ reconnaissance và cung cấp tài nguyên mở rộng cho các hoạt động reconnaissance.

- **Ví dụ:**

Ví dụ chức năng AWS Lambda cho reconnaissance

```
exports.handler = async (event) => {
    const response = await fetch('https://api.example.com/system-info');
    return response.json();
};
```

- **Tham khảo:** AWS Lambda Documentation

Bằng cách tận dụng những công cụ và công nghệ này, các tổ chức có thể thực hiện hiệu quả việc **active reconnaissance** trong môi trường **zero trust** trong khi giảm thiểu rủi ro bị phát hiện và đảm bảo tuân thủ các tiêu chuẩn pháp lý và đạo đức.

Phân Tích Cơ Chế Phát Hiện và Hạn Chế của Chúng

Giới thiệu

Cơ chế phát hiện trong các thiết lập bảo mật **Zero Trust** là rất quan trọng để nhận diện và giảm thiểu các nỗ lực **active reconnaissance**. Tuy nhiên, những cơ chế này cũng có những hạn chế mà cần được hiểu rõ để bảo vệ hiệu quả cho các mạng nội bộ.

Cơ Chế Phát Hiện

1. Hệ Thống Phát Hiện Xâm Nhập (IDS) và Hệ Thống Ngăn Chặn Xâm Nhập (IPS)

- **Hệ Thống IDS/IPS:** Các hệ thống này theo dõi lưu lượng mạng để phát hiện dấu hiệu truy cập trái phép hoặc hoạt động độc hại. Chúng có thể phát hiện những bất thường trong hành vi mạng, chẳng hạn như các truy vấn DNS không bình thường hoặc quét cổng, là những hành động phổ biến trong **active reconnaissance** [5].
- **Cấu Hình:** Hệ thống IDS/IPS có thể được cấu hình để theo dõi các giao thức cụ thể như DNS, HTTP và FTP. Ví dụ, việc cấu hình một IDS để theo dõi lưu lượng DNS có thể giúp phát hiện các truy vấn DNS nghi ngờ [3].

2. Tường Lửa

- **Quy Tắc Tường Lửa:** Tường lửa có thể được thiết lập để chặn các loại lưu lượng cụ thể, chẳng hạn như các kết nối đến không mong muốn hoặc các yêu cầu DNS đầu ra không bình thường. Điều này có thể giúp ngăn chặn các cuộc quét **reconnaissance** đến mục tiêu của chúng [5].
- **Lệnh CLI:** Để cấu hình tường lửa chặn các truy vấn DNS nghi ngờ, bạn có thể sử dụng lệnh như `iptables` trên các hệ thống Linux:

```
sudo iptables -A OUTPUT -p udp --dport 53 -j DROP
```

Lệnh này chặn tất cả lưu lượng UDP đầu ra trên cổng 53 (DNS), giúp ngăn chặn **reconnaissance** dựa trên DNS [2].

3. Hệ Thống Quản Lý Thông Tin và Sự Kiện Bảo Mật (SIEM)

- **Tích Hợp SIEM:** Các hệ thống SIEM tích hợp nhật ký từ nhiều nguồn khác nhau để cung cấp cái nhìn toàn diện về hoạt động mạng. Chúng có thể phát hiện các mẫu chỉ ra hoạt động **active reconnaissance**, chẳng hạn như nhiều truy vấn DNS từ cùng một địa chỉ IP trong thời gian ngắn [3].
- **Cấu Hình:** Để tích hợp hệ thống SIEM với nhật ký DNS, bạn có thể sử dụng API hoặc các giao thức chuyển tiếp nhật ký như Syslog. Ví dụ, cấu hình một SIEM để nhận nhật ký DNS từ một máy chủ DNS có thể giúp nhận diện hoạt động nghi ngờ:

```
sudo journalctl -u dnsmasq -f | grep "query"
```

Lệnh này ghi lại các truy vấn DNS từ dịch vụ `dnsmasq`, có thể được đưa vào hệ thống SIEM để phân tích [3].

4. Phân Khúc Mạng

- **Micro-Segmentation:** Phân khúc mạng liên quan đến việc chia nhỏ mạng thành các phân đoạn nhỏ hơn để giới hạn sự lan truyền của các cuộc tấn công tiềm năng. Điều này có thể giúp chứa các cuộc quét **reconnaissance** trong các phân đoạn cụ thể của mạng, làm cho việc phát hiện và phản ứng với chúng trở nên dễ dàng hơn [1].
- **Cấu Hình:** Việc triển khai **micro-segmentation** bao gồm cấu hình các chính sách mạng để hạn chế quyền truy cập giữa các phân đoạn. Ví dụ, sử dụng công cụ như Cisco's ACI (Application Centric Infrastructure) để tạo các micro-segment dựa trên yêu cầu của ứng dụng: `aciapp: create -name <segment_name> -type <segment_type>`. Lệnh này tạo ra một micro-segment mới với các chính sách cụ thể để kiểm soát lưu lượng [1].

Hạn Chế của Cơ Chế Phát Hiện

1. **Cảnh Báo Giả**
 - Các cơ chế phát hiện có thể sinh ra các cảnh báo giả, tức là các cảnh báo cho thấy có mối đe dọa tiềm tàng nhưng thực tế lại là các hoạt động vô hại. Điều này có thể dẫn đến việc phân bổ tài nguyên không cần thiết và có khả năng phá vỡ các dịch vụ hợp pháp [5].
2. **Kỹ Thuật Tránh Phát Hiện**
 - Các kẻ tấn công có thể sử dụng các kỹ thuật tránh phát hiện để tránh bị nhận diện. Ví dụ, việc sử dụng các truy vấn DNS được mã hóa (DoH/DoT) có thể làm khó khăn cho các hệ thống IDS/IPS truyền thống trong việc phát hiện các hành động **reconnaissance** dựa trên DNS [3].
3. **Giới Hạn Tài Nguyên**
 - Các cuộc quét **reconnaissance** khối lượng lớn có thể làm quá tải các cơ chế phát hiện, dẫn đến việc bỏ lỡ cảnh báo hoặc phản ứng chậm trễ. Điều này đặc biệt thách thức trong các môi trường có nguồn lực hạn chế hoặc khối lượng lưu lượng cao [5].
4. **Thiếu Tính Nhìn Thấy Thời Gian Thực**
 - Một số cơ chế phát hiện có thể không cung cấp tính nhìn thấy thời gian thực vào hoạt động mạng, điều này có thể làm chậm phản ứng với các nỗ lực **active reconnaissance**. Khoảng trống trong tính nhìn thấy này có thể được giảm thiểu bằng cách tích hợp các công cụ giám sát thời gian thực với các hệ thống SIEM [3].

Kết Luận

Hiểu rõ các hạn chế của các cơ chế phát hiện là yếu tố quan trọng để bảo vệ hiệu quả trong các môi trường **Zero Trust**. Bằng cách thừa nhận những hạn chế này và triển khai các cơ chế phát hiện mạnh mẽ, các tổ chức có thể giảm thiểu tốt hơn các rủi ro liên quan đến **active reconnaissance**. Việc giám sát liên tục, cập nhật định kỳ và thông tin tình báo mối đe dọa tiên tiến là cần

thiết để luôn đi trước các mối đe dọa đang phát triển.

Tài liệu tham khảo

- [1] The Hacker News: “What it Means to ‘Fight AI with AI’ using a Zero Trust Platform”
- [2] CableLabs: “False Base Station or IMSI Catcher: What You Need to Know”
- [3] Cygnalabs: “Why DNS Security is the Missing Link in Zero Trust Strategies”
- [5] Webasha: “What is Active Footprinting in Cybersecurity and Why Does It Matter?”

Case Studies: Real-world Examples of Covert Reconnaissance

Giới thiệu

Phần này sẽ phân tích các ví dụ thực tế về **covert reconnaissance** trong bối cảnh an ninh **Zero Trust**, làm nổi bật các kỹ thuật và công cụ mà kẻ tấn công sử dụng cũng như các cơ chế phát hiện mà người bảo vệ áp dụng.

Ví dụ 1: Khai thác DNS

Tình huống: Một kẻ tấn công sử dụng khai thác DNS để thu thập thông tin về mạng nội bộ của một tổ chức mục tiêu.

Kỹ thuật: Kẻ tấn công thực hiện các truy vấn DNS để xác định tên miền phụ và địa chỉ IP nội bộ. Điều này có thể được thực hiện thông qua các công cụ như `nslookup` hoặc `dig`.

Phát hiện: Để phát hiện các hoạt động này, các tổ chức nên triển khai các biện pháp bảo mật DNS như: - **Split-Horizon DNS:** Đảm bảo rằng các bản ghi DNS nội bộ không bị lộ ra các truy vấn bên ngoài. Điều này có thể đạt được bằng cách cấu hình các chế độ xem DNS riêng cho các truy vấn nội bộ và bên ngoài[3]. - **DNSSEC:** Thực hiện các Mở rộng Bảo mật DNS (DNSSEC) để bảo vệ khỏi các cuộc tấn công giả mạo DNS và tấn công ngụy tạo bộ nhớ cache[3]. - **Giám sát:** Tích hợp bảo mật DNS với các nền tảng SIEM để giám sát liên tục và phát hiện anomaly[3].

Ví dụ lệnh CLI:

```
# Thực hiện truy vấn DNS để xác định tên miền phụ
nslookup -type=ns example.internaldomain.com
```

Ví dụ 2: Quét cổng

Tình huống: Một kẻ tấn công sử dụng quét cổng để xác định các cổng mở trên mạng nội bộ của một tổ chức mục tiêu.

Kỹ thuật: Kẻ tấn công sử dụng các công cụ như Nmap để quét các cổng mở và dịch vụ.

Phát hiện: Để phát hiện các hoạt động quét cổng, các tổ chức nên: - **Triển khai Phân khúc Mạng:** Phân khúc mạng để hạn chế quyền truy cập vào các tài nguyên quan trọng. Điều này có thể được thực hiện bằng cách sử dụng tường lửa và hệ thống kiểm soát truy cập mạng (NAC)[1]. - **Sử dụng Hệ thống Phát hiện Xâm nhập (IDS):** Triển khai các hệ thống IDS có thể phát hiện và cảnh báo về các hoạt động mạng nghi ngờ, bao gồm quét cổng[5]. - **Giám sát Nhật ký:** Thường xuyên theo dõi nhật ký hệ thống để phát hiện dấu hiệu truy cập trái phép hoặc hoạt động quét.

Ví dụ lệnh CLI:

```
# Thực hiện quét cổng bằng Nmap  
nmap -sS -T4 target.internalipaddress
```

Ví dụ 3: Kỹ thuật Kỹ thuật xã hội

Tình huống: Một kẻ tấn công sử dụng các thủ thuật kỹ thuật xã hội để thu thập thông tin về mạng nội bộ của một tổ chức mục tiêu.

Kỹ thuật: Kẻ tấn công gửi email giả mạo hoặc sử dụng các kỹ thuật kỹ thuật xã hội khác để lừa nhân viên tiết lộ thông tin nhạy cảm.

Phát hiện: Để phát hiện các cuộc tấn công kỹ thuật xã hội, các tổ chức nên: - **Đào tạo nhân viên:** Tổ chức các buổi đào tạo định kỳ để giáo dục nhân viên về cách nhận diện và báo cáo các nỗ lực lừa đảo[5]. - **Triển khai MFA:** Sử dụng xác thực đa yếu tố (MFA) để bổ sung một lớp bảo mật nữa nhằm ngăn chặn các kẻ tấn công truy cập vào thông tin nhạy cảm[3]. - **Giám sát Hoạt động Email:** Theo dõi thường xuyên hoạt động email để phát hiện các tin nhắn đáng ngờ và triển khai các giải pháp bảo mật email có thể phát hiện và chặn các nỗ lực lừa đảo.

Ví dụ thực tế: Năm 2023, một công ty đã báo cáo về một cuộc tấn công lừa đảo mà một kẻ tấn công đã gửi một email giả mạo mô phỏng phòng IT, yêu cầu nhân viên thay đổi mật khẩu. Cuộc tấn công đã được phát hiện khi các nhân viên báo cáo email nghi ngờ, và đội ngũ an ninh của công ty đã chặn cuộc tấn công trước khi xảy ra thiệt hại[5].

Ví dụ 4: Đánh dấu tích cực

Tình huống: Một kẻ tấn công sử dụng các kỹ thuật đánh dấu tích cực để thu thập thông tin chi tiết về mạng nội bộ của một tổ chức mục tiêu.

Kỹ thuật: Kẻ tấn công sử dụng các công cụ như enum4linux để lấy danh sách tài khoản người dùng từ một máy chủ Windows cấu hình sai hoặc thực hiện khai thác DNS để xác định các tên miền phụ[5].

Phát hiện: Để phát hiện các hoạt động đánh dấu tích cực, các tổ chức nên:

- **Triển khai Tường lửa và IDS:** Triển khai các hệ thống tường lửa và IDS có thể phát hiện và cảnh báo về các hoạt động mạng nghi ngờ, bao gồm các kỹ thuật đánh dấu tích cực[5].
- **Giám sát Nhật ký:** Theo dõi thường xuyên nhật ký hệ thống để phát hiện dấu hiệu truy cập trái phép hoặc hoạt động trình sát.
- **Củng cố hệ thống:** Thường xuyên củng cố hệ thống bằng cách vô hiệu hóa các dịch vụ không cần thiết và đóng các cổng không sử dụng để giảm diện tích tấn công[5].

Ví dụ lệnh CLI:

```
# Thực hiện liệt kê bằng enum4linux
enum4linux -a target.internalipaddress
```

Kết luận

Covert reconnaissance trong các thiết lập bảo mật **Zero Trust** là một mối đe dọa phức tạp và đang phát triển. Bằng cách hiểu rõ các kỹ thuật và công cụ mà kẻ tấn công sử dụng, các tổ chức có thể chuẩn bị tốt hơn cho công tác phòng thủ của mình. Việc triển khai các biện pháp bảo mật mạnh mẽ như bảo mật DNS, phân khúc mạng và giám sát liên tục có thể giúp giảm thiểu rủi ro liên quan đến hoạt động trình sát ngầm. Các chương trình đào tạo và nâng cao nhận thức cho nhân viên cũng rất quan trọng trong việc ngăn chặn các cuộc tấn công kỹ thuật xã hội. Bằng cách duy trì sự cảnh giác và chủ động, các tổ chức có thể giảm thiểu đáng kể nguy cơ các cuộc tấn công trình sát thành công.

Tài liệu tham khảo

- [1] The Hacker News: “What it Means to ‘Fight AI with AI’ using a Zero Trust Platform”
- [3] Cygnalabs: “Why DNS Security is the Missing Link in Zero Trust Strategies”
- [5] Webasha: “What is Active Footprinting in Cybersecurity and Why Does It Matter?”

Đánh giá rủi ro và hệ lụy về bảo mật

Giới thiệu

Active reconnaissance trong các thiết lập **Zero Trust** mang đến những rủi ro đáng kể mà cần phải được đánh giá và giảm thiểu. Phần này sẽ đi sâu vào các hệ lụy về bảo mật của hoạt động **reconnaissance** chủ động và cung cấp các chiến lược để giảm thiểu rủi ro.

Các mối đe dọa và lỗ hổng

Active reconnaissance bao gồm việc tương tác trực tiếp với hệ thống mục tiêu, điều này có thể dẫn đến một số mối đe dọa về bảo mật:

- **Phát hiện:** Các phương pháp **active reconnaissance** như truy vấn DNS, quét cổng và kỹ thuật **social engineering** có thể kích hoạt cảnh báo trong các hệ thống phát hiện xâm nhập (**IDS**) và tường lửa, làm cho chúng trở nên dễ phát hiện hơn[5].
- **Vấn đề pháp lý:** Thực hiện **active reconnaissance** trên các mục tiêu không được ủy quyền là vi phạm pháp luật và không đạo đức. Cần phải có sự cho phép rõ ràng trước khi tiến hành các hoạt động như vậy[5].
- **Gián đoạn hệ thống:** Quá trình quét một cách mạnh mẽ có thể làm sập các dịch vụ không ổn định, dẫn đến sự gián đoạn hệ thống[5].

Chiến lược giảm thiểu

Để giảm thiểu các rủi ro liên quan đến **active reconnaissance**, các tổ chức nên thực hiện các chiến lược sau:

- **Tăng cường cấu hình DNS:** Vô hiệu hóa chuyển vùng để ngăn chặn truy cập trái phép vào các bản ghi DNS[3].
- **Triển khai tường lửa và IDS/IPS:** Việc triển khai tường lửa và hệ thống phát hiện/ngăn chặn xâm nhập (**IDS/IPS**) có thể giúp phát hiện và chặn các hoạt động độc hại[2][5].
- **Giám sát hoạt động bất thường:** Theo dõi thường xuyên hành vi quét DNS và mạng để phát hiện các hoạt động bất thường[5].
- **Đào tạo nhân viên:** Giáo dục nhân viên để phát hiện và báo cáo các nỗ lực **social engineering**, những nỗ lực này thường gặp trong **active reconnaissance**[5].
- **Giới hạn dịch vụ không cần thiết:** Đóng các cổng không sử dụng và giới hạn các dịch vụ không cần thiết để giảm bề mặt tấn công[5].

Kỹ thuật giảm thiểu nâng cao

Ngoài các chiến lược ở trên, một số kỹ thuật nâng cao có thể gia tăng thêm an ninh:

- **Microsegmentation:** Triển khai **microsegmentation** để cách ly các tài nguyên mạng, ngăn chặn việc di chuyển trái phép trong trường hợp có một cuộc tấn công[1].
- **Giám sát liên tục:** Tích hợp an ninh DNS với các nền tảng **SIEM** để giám sát liên tục và phát hiện bất thường nâng cao[3].
- **Phản hồi mối đe dọa tự động:** Sử dụng các cơ chế phản hồi mối đe dọa tự động để nhanh chóng phản ứng với các mối đe dọa đã phát hiện, giảm thiểu tác động của một cuộc xâm nhập tiềm tàng[3].

Ví dụ cấu hình

Ví dụ, để tăng cường các cấu hình DNS, bạn có thể sử dụng lệnh sau để vô hiệu hóa chuyển vùng:

```
sudo sed -i 's/allow-transfer.*/allow-transfer none;/g' /etc/named.conf
```

Lệnh này chỉnh sửa tệp **named.conf** để vô hiệu hóa chuyển vùng, từ đó ngăn chặn truy cập trái phép vào các bản ghi DNS[3].

Kết luận

Active reconnaissance trong các thiết lập **Zero Trust** là một giai đoạn quan trọng cần được đánh giá và giảm thiểu rủi ro một cách cẩn thận. Bằng cách triển khai các biện pháp bảo mật vững chắc như tăng cường cấu hình DNS, triển khai tường lửa và **IDS/IPS**, và đào tạo nhân viên, các tổ chức có thể giảm thiểu đáng kể các rủi ro liên quan đến **active reconnaissance**. Việc giám sát liên tục và cơ chế phản hồi mỗi đe dọa tự động còn gia tăng thêm tư thế an toàn cho tổ chức.

Tài liệu tham khảo

- [1] The Hacker News. “What it Means to ‘Fight AI with AI’ using a Zero Trust Platform.” 2025-03-31.
- [2] CableLabs. “False Base Station or IMSI Catcher: What You Need to Know.” 2025-03-11.
- [3] Cygna Labs. “Why DNS Security is the Missing Link in Zero Trust Strategies.” 2025-03-25.
- [5] Webasha. “What is Active Footprinting in Cybersecurity and Why Does It Matter?” 2025-04-04.

Compliance and Legal Considerations in Active Reconnaissance

Giới thiệu

Các yếu tố **tuân thủ** và **pháp lý** đóng vai trò quan trọng trong bối cảnh **reconnaissance chủ động** trong môi trường bảo mật **Zero Trust**. Sự tinh vi ngày càng tăng của các mối đe dọa mạng yêu cầu một kiến thức sâu sắc về môi trường pháp lý để đảm bảo rằng các hoạt động reconnaissance được thực hiện một cách **đạo đức** và tuân thủ luật pháp.

Các yếu tố pháp lý chính

1. Luật bảo vệ dữ liệu

- **GDPR (Quy định chung về bảo vệ dữ liệu):** Các tổ chức phải đảm bảo rằng mọi dữ liệu thu thập được trong quá trình hoạt động reconnaissance đều tuân thủ quy định của GDPR. Điều này bao gồm việc thu thập sự đồng ý rõ ràng từ cá nhân và đảm bảo rằng dữ liệu được xử lý một cách hợp pháp và minh bạch^[1].
- **CCPA (Đạo luật quyền riêng tư người tiêu dùng California):** Tương tự như GDPR, CCPA yêu cầu các tổ chức bảo vệ thông tin cá nhân của cư dân California và cung cấp cho họ một số quyền liên quan đến dữ liệu của mình^[2].

2. Luật riêng tư

- **HIPAA (Đạo luật về di động và trách nhiệm bảo hiểm y tế):** Nếu dữ liệu liên quan đến chăm sóc sức khỏe, cần tuân thủ quy định của HIPAA. Điều này bao gồm việc đảm bảo rằng thông tin y tế được bảo vệ (PHI) không bị tiết lộ mà không có sự cho phép thích hợp[³].

3. Quy định về an ninh mạng

- **NIST Cybersecurity Framework:** Khung quy định này cung cấp các hướng dẫn để quản lý và giảm thiểu rủi ro an ninh mạng. Nó bao gồm các khuyến nghị cho việc xác định, bảo vệ, phát hiện, ứng phó và phục hồi từ các mối đe dọa mạng[⁴].

4. Tuân thủ quy định

- **PCI-DSS (Tiêu chuẩn bảo mật dữ liệu ngành thanh toán):** Nếu thông tin thẻ thanh toán được liên quan, phải tuân thủ các quy định của PCI-DSS. Điều này bao gồm các yêu cầu về bảo mật mạng, bảo vệ dữ liệu và quản lý lỗ hổng[⁵].

Các thực tiễn tốt nhất cho việc tuân thủ

1. Chính sách và quy trình

- Phát triển các chính sách và quy trình rõ ràng cho việc thực hiện reconnaissance chủ động. Các chính sách này phải nêu rõ phạm vi hoạt động, phương pháp thu thập dữ liệu và thực hành lưu trữ.

2. Sự đồng ý và thông báo

- Thu thập sự đồng ý rõ ràng từ cá nhân trước khi thu thập dữ liệu của họ. Cung cấp thông báo rõ ràng về các thực hành thu thập và sử dụng dữ liệu.

3. Tối ưu hóa dữ liệu

- Chỉ thu thập tối thiểu dữ liệu cần thiết cho các hoạt động reconnaissance. Điều này giúp giảm thiểu rủi ro vi phạm dữ liệu và không tuân thủ pháp luật.

4. Dấu vết kiểm toán

- Duy trì các dấu vết kiểm toán chi tiết cho tất cả các hoạt động reconnaissance. Điều này giúp theo dõi công việc thu thập dữ liệu và đảm bảo rằng tất cả các hành động đều minh bạch và có trách nhiệm.

5. Đào tạo và nâng cao nhận thức

- Đảm bảo tất cả nhân viên tham gia các hoạt động reconnaissance được đào tạo về các yếu tố tuân thủ và pháp lý. Các chương trình nâng cao nhận thức thường xuyên có thể giúp duy trì văn hóa tuân thủ.

Các lệnh CLI và tệp cấu hình

Mặc dù các lệnh CLI và tệp cấu hình cụ thể có thể khác nhau tùy thuộc vào công cụ hoặc công nghệ được sử dụng, nhưng điều quan trọng là đảm bảo rằng

tất cả các hoạt động đều được ghi lại và kiểm toán. Ví dụ, sử dụng các công cụ như **sysdig** để giám sát mạng có thể giúp duy trì các bản ghi chi tiết cho tất cả các hoạt động.

```
# Example sysdig command to monitor network activity
sysdig -c netconn -p "netconn:conn_established"
```

Kết luận

Các yếu tố tuân thủ và pháp lý là thành phần thiết yếu của hoạt động reconnaissance chủ động trong bối cảnh bảo mật **Zero Trust**. Bằng việc tuân thủ các luật bảo vệ dữ liệu, quy định riêng tư và các khung an ninh mạng, các tổ chức có thể đảm bảo rằng các hoạt động reconnaissance của họ được thực hiện một cách đạo đức và trong khuôn khổ pháp luật. Các cuộc kiểm tra định kỳ, chính sách rõ ràng và nhân viên được đào tạo là rất quan trọng để duy trì sự tuân thủ.

Tài liệu tham khảo

- [1] GDPR: <https://gdpr-info.eu/>
- [2] CCPA: <https://oag.ca.gov/privacy/ccpa>
- [3] HIPAA: <https://www.hhs.gov/hipaa/index.html>
- [4] NIST Cybersecurity Framework: <https://www.nist.gov/cyberframework>
- [5] PCI-DSS: <https://www.pcisecuritystandards.org/>
- OWASP
- MITRE
- sysdig
- Acalvio
- Gartner
- sysdig documentation

Best Practices for Mitigating Risks Associated with Reconnaissance Scans in Zero Trust Environments

Implement Zero Trust Network Access (ZTNA)

- **Universal ZTNA:** Mở rộng ZTNA ra ngoài công nhân làm việc từ xa để bao gồm tất cả người dùng trong văn phòng nhằm đảm bảo mọi quyền truy cập đều được xác thực, giảm thiểu bề mặt tấn công [1].
- **Microsegmentation:** Tách biệt các tài nguyên và ứng dụng quan trọng bằng các kỹ thuật microsegmentation để ngăn chặn chuyển động bên trong và kiểm soát các cuộc tấn công [1].

Enhance DNS Security

- **Split-Horizon DNS:** Triển khai split-horizon DNS để tạo ra các chế độ xem DNS riêng biệt cho các truy vấn nội bộ và bên ngoài, giảm bớt khả năng bị tấn công truy vấn [3].

- **DNSSEC:** Sử dụng DNSSEC để bảo vệ chống lại việc giả mạo DNS và nhiễm độc bộ đệm, đảm bảo tính toàn vẹn dữ liệu [3].
- **Encrypted DNS:** Triển khai Encrypted DNS (DoH/DoT) để bảo mật các truy vấn DNS trước sự can thiệp [3].

Implement Robust Identity and Access Management (IAM)

- **Least-Privilege Access:** Đảm bảo rằng chỉ những nhân viên được ủy quyền mới có quyền truy cập vào các hệ thống và dữ liệu quan trọng, tuân theo nguyên tắc cấp quyền tối thiểu [3].
- **Multi-Factor Authentication (MFA):** Yêu cầu MFA cho tất cả người dùng để thêm một lớp bảo mật bổ sung, khiến việc truy cập trái phép trở nên khó khăn hơn [3].

Continuous Monitoring and Threat Detection

- **SIEM Integration:** Tích hợp bảo mật DNS với các nền tảng SIEM để theo dõi liên tục và phát hiện bất thường nâng cao [3].
- **AI-Driven Analytics:** Tận dụng phân tích dựa trên AI để nhận diện các hành vi DNS khả nghi cho thấy các mối đe dọa mạng [3].

Network Segmentation

- **Restrict DNS Resolution:** Giới hạn việc giải quyết DNS cho các ứng dụng quan trọng nhằm ngăn chặn các truy vấn DNS trái phép [3].
- **Firewall Rules:** Áp dụng quy tắc tường lửa để chặn các yêu cầu DNS ra ngoài từ các thiết bị không có quyền [3].

Vulnerability Management

- **Prioritize Actively Exploited CVEs:** Đẩy mạnh việc vá lỗi cho các CVE đang bị khai thác tích cực hơn là những lỗ hổng nghiêm trọng nhưng hiếm khi bị khai thác, sử dụng AI để nâng cao quy trình ưu tiên [1].
- **Unified Vulnerability Management:** Thực hiện quản lý lỗ hổng thống nhất để triage các lỗ hổng chưa được giải quyết và giảm bớt bề mặt tấn công [1].

Cyber Deception

- **Honeytokens:** Sử dụng honeytokens để tạo ra những cái bẫy mô phỏng tài sản hợp pháp, kích hoạt phát hiện sớm về ý định độc hại [5].
- **Decoy Assets:** Triển khai các tài sản giả mạo thiết kế để giống như các mục tiêu có giá trị cao, chẳng hạn như cơ sở dữ liệu hoặc máy chủ, nhằm chuyển hướng các kẻ tấn công ra khỏi hệ thống sản xuất [5].

Regular Audits and Logging

- **Log Configuration Changes:** Ghi lại và kiểm toán các thay đổi cấu hình DNS để phát hiện các thay đổi trái phép theo thời gian thực [3].
- **Regular Audits:** Thực hiện kiểm tra định kỳ các tài nguyên và cấu hình mạng để xác định các lỗ hổng và các cấu hình sai lệch.

Bằng cách triển khai các **thực tiễn tốt nhất** này, các tổ chức có thể giảm thiểu đáng kể rủi ro liên quan đến các cuộc quét truy vấn trong môi trường Zero Trust, từ đó nâng cao tư thế bảo mật tổng thể của họ.

Tài liệu tham khảo: - [1] The Hacker News: “What it Means to ‘Fight AI with AI’ using a Zero Trust Platform” - [3] Cygnalabs: “Why DNS Security is the Missing Link in Zero Trust Strategies” - [5] Acalvio: “Cyber Deception and the Case for Preemptive Cybersecurity Defense”

Future Trends in Active Reconnaissance Techniques

1. Tiến bộ trong nhận thức dựa trên AI

- **Công cụ quét được hỗ trợ bởi AI:** Việc tích hợp AI và **machine learning (ML)** vào các công cụ nhận thức dự kiến sẽ nâng cao khả năng của chúng. Những công cụ này có thể phân tích mẫu lưu lượng mạng, xác định những lỗ hổng và dự đoán chính xác hơn các vectơ tấn công tiềm tàng[1].
- **Phân tích dự đoán:** Phân tích dự đoán dựa trên AI có thể giúp các nhóm bảo mật dự đoán và chuẩn bị cho các hoạt động nhận thức tiềm ẩn bằng cách phân tích dữ liệu lịch sử và xác định các xu hướng[1].

2. Tăng cường sử dụng kỹ thuật đánh lừa

- **Công nghệ đánh lừa:** Việc sử dụng các kỹ thuật đánh lừa như **honey-tokens** và hệ thống giả mạo đang trở nên phổ biến hơn. Những phương pháp này có thể phát hiện và làm lệch hướng các kẻ tấn công khỏi các tài sản quan trọng bằng cách tạo ra các mục tiêu giả, giống như thật[5].
- **Mồi giả mạo được tạo bởi AI:** Các mồi giả mạo tiên tiến được thiết kế bằng AI có thể xuất hiện có giá trị cao và dễ bị khai thác, khiến chúng trở thành mục tiêu hấp dẫn cho kẻ tấn công. Điều này cho phép các nhà bảo vệ thu thập và phân tích các exploit theo thời gian thực, thu được những hiểu biết quý báu về các chiến thuật, kỹ thuật và quy trình mới (TTPs)[5].

3. Phân đoạn mạng được nâng cao

- **Microsegmentation:** Thực hành microsegmentation mạng để cách ly các tài nguyên quan trọng đang trở nên tinh vi hơn. Điều này liên quan đến việc chia nhỏ mạng thành các phân đoạn nhỏ hơn và áp dụng các

kiểm soát truy cập nghiêm ngặt cho từng phân đoạn, giảm thiểu bề mặt tấn công[1].

- **Zero Trust Network Access (ZTNA):** Việc mở rộng ZTNA để bao gồm tất cả nhân viên, cả làm việc từ xa và tại văn phòng, đảm bảo rằng tất cả yêu cầu truy cập được xác thực và ủy quyền riêng lẻ, giảm thiểu rủi ro từ các cuộc tấn công di chuyển ngang[1].

4. Cải thiện bảo mật DNS

- **Các cải tiến trong bảo mật DNS:** Việc tích hợp bảo mật DNS vào các khung Zero Trust là vô cùng quan trọng. Điều này bao gồm các kỹ thuật như **Split-Horizon DNS**, tạo ra các chế độ DNS tách biệt cho các truy vấn nội bộ và bên ngoài, giảm thiểu sự tiếp xúc với các cuộc tấn công nhận thức[3].
- **DNSSEC và DNS được mã hóa:** Triển khai DNSSEC để đảm bảo toàn vẹn dữ liệu và sử dụng các giao thức DNS mã hóa như DoH/DoT có thể bảo vệ chống lại giả mạo DNS và tấn công tràn bộ nhớ cache, nâng cao bảo mật mạng tổng thể[3].

5. Phát hiện và phản ứng với mối đe dọa nâng cao

- **Phát hiện mối đe dọa dựa trên AI:** Việc sử dụng phân tích dựa trên AI trong các nền tảng **SIEM** có thể nâng cao việc giám sát liên tục và phát hiện bất thường tiên tiến. Điều này giúp xác định các hành vi DNS nghi ngờ có thể báo hiệu các mối đe dọa mạng, cải thiện thời gian phản ứng sự cố[3].
- **Thiết lập chính sách tự động:** Các giải pháp như **Cyigna Labs** cho phép thiết lập chính sách tự động, đảm bảo tuân thủ các chính sách Zero Trust bằng cách phát hiện và giảm thiểu các bất thường DNS trong thời gian thực[3].

6. Quản lý lỗ hổng nâng cao

- **Ưu tiên các CVE đang bị khai thác:** Tập trung vào quản lý lỗ hổng bằng cách ưu tiên các CVE đang bị khai thác thay vì những CVE có đánh giá độ nghiêm trọng cao có thể tạo ra sự khác biệt đáng kể trong việc giảm khả năng khai thác. AI có thể cải thiện quy trình này bằng cách cung cấp sự ưu tiên thông minh hơn[1].
- **Quản lý lỗ hổng thống nhất:** Triển khai quản lý lỗ hổng thống nhất giúp các tổ chức phân loại hiệu quả các lỗ hổng còn lại của họ, giảm thiểu bề mặt tấn công[1].

7. Hướng nghiên cứu tương lai

- **Nghiên cứu về giảm thiểu tấn công trạm gốc giả (FBS):** Nghiên cứu liên tục về giảm thiểu tấn công **FBS** trong các mạng 5G là rất quan trọng. Các giải pháp như bảo vệ tính toàn vẹn của các thông điệp phát

sống và mã hóa khóa công khai của các định danh người dùng vĩnh viễn (SUPI) đang được khám phá[2].

- **Tích hợp với các công nghệ mới nổi:** Việc tích hợp các kỹ thuật nhận thức chủ động với các công nghệ mới nổi như **blockchain** và **edge computing** sẽ là một lĩnh vực nghiên cứu tương lai, nhằm nâng cao bảo mật và độ bền trong các mạng phức tạp[2].

Bằng cách tập trung vào những xu hướng tương lai này, các tổ chức có thể chuẩn bị tốt hơn và giảm thiểu rủi ro liên quan đến **nhận thức chủ động** trong các thiết lập bảo mật **Zero Trust**, đảm bảo một tư thế an ninh mạng năng động và mạnh mẽ hơn.

Kết luận và Khuyến nghị cho các Chuyên gia An ninh

Tóm tắt các Phát hiện Quan trọng

Hoạt động **reconnaissance** chủ động trong các thiết lập bảo mật **Zero Trust** đặt ra những thách thức đáng kể do tính chất phân khúc và biến động của các môi trường này. Mặc dù những thách thức này, việc các chuyên gia an ninh duy trì sự cảnh giác và chủ động trong việc giảm thiểu các mối đe dọa reconnaissance là vô cùng quan trọng. Dưới đây là các phát hiện và khuyến nghị chính:

Khuyến nghị Giảm thiểu Rủi ro Liên quan đến Quét Reconnaissance

1. Triển khai Các Nguyên tắc Zero Trust

- **Microsegmentation:** Cô lập các tài nguyên và tài sản quan trọng để ngăn chặn chuyển động ngang và truy cập trái phép. Điều này có thể đạt được thông qua các kỹ thuật như phân đoạn mạng và micro-segmentation [1].
- **Giám sát Liên tục:** Sử dụng các công cụ giám sát liên tục và phát hiện mối đe dọa để nhận diện hoạt động nghi ngờ sớm. Phân tích dựa trên AI có thể nâng cao khả năng hiển thị và tự động hóa các hành động phản ứng [3].

2. Tăng cường An ninh DNS

- **DNSSEC:** Triển khai Mở rộng Bảo mật DNS (DNSSEC) để bảo vệ chống lại việc giả mạo DNS và đầu độc bộ nhớ đệm. Điều này đảm bảo tính toàn vẹn và xác thực của các truy vấn DNS [3].
- **DNS Horizon Tách biệt:** Sử dụng DNS Horizon tách biệt để tạo ra các chế độ xem DNS riêng biệt cho các truy vấn nội bộ và bên ngoài, làm giảm khả năng bị tấn công reconnaissance [3].

3. Triển khai Kỹ thuật Lừa đảo

- **Honeytokens:** Sử dụng giải pháp phát hiện và phản ứng mối đe dọa danh tính (ITDR) với honeytokens để tạo ra các môi trường mô phỏng tài sản hợp pháp. Điều này giúp phát hiện các mối đe dọa sớm và lặng lẽ, không phụ thuộc vào phát hiện dựa trên mẫu [5].

4. Quản lý Lỗ hổng

- **Ưu tiên Các CVEs Bị Khai thác:** Tập trung vào việc vá các lỗ hổng đang bị khai thác tích cực hơn là những lỗ hổng có mức độ nghiêm trọng cao. AI có thể nâng cao quy trình ưu tiên này bằng cách phân tích xu hướng khai thác và các lỗ hổng [1].
5. **Mô hình Hóa Mối đe dọa và Đánh giá Rủi ro**
 - **Xác định Các Vectơ Tấn công:** Thực hiện mô hình hóa mối đe dọa kỹ lưỡng để xác định các vectơ tấn công tiềm ẩn trong các mạng zero trust. Điều này bao gồm phân tích các tài nguyên mạng, phương pháp liệt kê và các kỹ thuật quét lén.
 - **Đánh giá Rủi ro:** Đánh giá thường xuyên các rủi ro liên quan đến các quét reconnaissance và cập nhật các biện pháp bảo mật cho phù hợp. Điều này bao gồm giám sát liên tục các hoạt động trên mạng và điều chỉnh chính sách dựa trên các mối đe dọa và lỗ hổng mới.
 6. **Cân nhắc về Tuân thủ và Pháp lý**
 - **Tuân thủ Quy định:** Đảm bảo rằng tất cả các biện pháp bảo mật đều tuân thủ các quy định và tiêu chuẩn liên quan, chẳng hạn như những gì được quy định bởi NIST hoặc GDPR. Điều này bao gồm việc duy trì các nhật ký và hồ sơ chi tiết về các hoạt động bảo mật.
 7. **Thực tiễn Tốt nhất để Giảm thiểu Rủi ro**
 - **Kiểm tra và Thử nghiệm B xâm nhập Thường xuyên:** Thực hiện các cuộc kiểm tra và thử nghiệm xâm nhập định kỳ để xác định các lỗ hổng và điểm yếu trong mạng. Điều này giúp củng cố tổng thể tư thế bảo mật.
 - **Giáo dục và Nâng cao Nhận thức Cho Nhân viên:** Đào tạo nhân viên về các rủi ro liên quan đến quét reconnaissance và tầm quan trọng của việc báo cáo các hoạt động nghi ngờ. Điều này có thể giúp ngăn chặn các mối đe dọa nội bộ.
 8. **Xu hướng Tương lai trong Kỹ thuật Reconnaissance Chủ động**
 - **Phát hiện Mối đe dọa Dựa trên AI:** Tận dụng các công cụ phát hiện mối đe dọa dựa trên AI để nâng cao hiệu quả phát hiện mối đe dọa reconnaissance. Những công cụ này có thể phân tích mẫu lưu lượng mạng và nhận diện bất thường một cách hiệu quả hơn so với các phương pháp truyền thống [1][4].
 - **Kỹ thuật Lừa đảo Nâng cao:** Khám phá các kỹ thuật lừa đảo nâng cao như việc sử dụng các môi thử do AI tạo ra để mô phỏng các tài sản có giá trị cao. Điều này có thể giúp chuyển hướng kẻ tấn công ra khỏi các hệ thống quan trọng và cung cấp các tín hiệu phát hiện sớm [5].

Kết luận

Hoạt động reconnaissance chủ động trong các thiết lập bảo mật zero trust là một thách thức phức tạp đòi hỏi một cách tiếp cận đa chiều. Bằng cách triển khai các nguyên tắc zero trust, tăng cường an ninh DNS, sử dụng các kỹ thuật lừa đảo, ưu tiên quản lý lỗ hổng, thực hiện mô hình hóa mối đe dọa kỹ lưỡng, đảm bảo tuân thủ quy định và thực hiện các thực tiễn tốt nhất để giảm thiểu,

các chuyên gia an ninh có thể giảm thiểu đáng kể các rủi ro liên quan đến các quét reconnaissance. Thêm vào đó, việc cập nhật với các xu hướng trong tương lai về phát hiện mối đe dọa dựa trên AI và các kỹ thuật lừa đảo nâng cao sẽ là yếu tố quan trọng để duy trì một tư thế bảo mật mạnh mẽ trong môi trường mạng ngày càng hostile.

Tài liệu tham khảo

- [1] The Hacker News: “What it Means to ‘Fight AI with AI’ using a Zero Trust Platform”
- [3] Cygnalabs: “Why DNS Security is the Missing Link in Zero Trust Strategies”
- [5] Acalvio: “Cyber Deception and the Case for Preemptive Cybersecurity Defense”

